

(주)해랑금융 수탁사 점검 계획서

수탁사 (피감사)	(주)해랑금융
위탁사 (감사 주체)	(주)하랑항공
위탁 업무 범위	항공 마일리지 연계 결제 API 중계, 결제 데이터 수신·저장·정산, 카드사 연동 토큰화 처리
보고서 작성일	2026년 01월 23일

본 계획서는 (주)하랑항공이 위탁한 마일리지 연계 결제 API 중계 및 금융 데이터 처리·정산 업무 수행과 관련하여 (주)해랑금융의 개인정보 보호 관리 수준을 유지하기 위한 점검 계획을 기술한 문서입니다.

개 정 이 력

버전	변경일	변경 사유	변경 내용	작성자	비고
1.0	2026-01-05	최초 작성	계획서 최초 작성	(주)리베로	
1.1	2026-01-08	내용 수정	양식 및 절차 수정	(주)리베로	
1.2	2026-01-12	내용 수정	점검 개요 및 관련 근거 작성	(주)리베로	
1.3	2026-01-17	내용 수정	점검계획 및 일정 작성	(주)리베로	
1.4	2026-01-23	내용 수정	점검항목 작성	(주)리베로	

목 차

1. 관련 근거	5
2. 점검 배경	6
3. 점검 개요	6
4. 점검 계획	7
5. 점검 일정	8
6. 점검 항목	9

표 목차

[표 1] 점검일정표	8
[표 2] 내부 관리 계획 및 조직 점검항목	9
[표 3] 접근 통제 및 권한 관리 점검항목	9
[표 4] 접속기록 보관 및 점검 점검항목	10
[표 5] 비밀번호 관리 점검항목	10
[표 6] 접속 보안 및 네트워크 점검항목	10
[표 7] 단말기 보안 점검항목	10
[표 8] 개인정보 암호화 및 출력 통제 점검항목	11
[표 9] 개인정보 생명주기 점검항목	11

본 계획은 위탁자의 개인정보 처리 업무를 위탁한 수탁자의 개인정보 처리 시스템 및 관리 실태에 대한 점검을 목적으로 한다.

수탁자가 보유하거나 처리하는 개인정보 파일에 대한 유출 사고를 방지하고 수탁자의 개인정보 처리 시스템이 관련 법규 및 위탁 계약 기준에 따라 적절하게 구성 및 운영되는지 확인한다.

이를 통해 수탁자에 대한 개인정보 관리체계 수준을 향상하고, 위탁자가 제공한 개인정보의 안전성을 확보하는 것을 목표로, 위탁자는 수탁자의 개인정보 처리 현장에 대한 점검을 실시한다.

1. 관련 근거

- 개인정보보호법 제26조(업무위탁에 따른 개인정보의 처리 제한)
- 개인정보보호법 제29조(안전조치의무)
- 개인정보보호법 시행령 제28조(개인정보의 안전성 확보 조치)
- 개인정보보호법 시행령 제28조의2(개인정보 처리업무의 위탁에 따른 보호조치 등)
- 개인정보의 안전성 확보조치 기준(개인정보보호위원회 고시)

2. 점검 배경

- 최근 금융·결제 분야 개인정보 유출 사고가 지속 발생함에 따라, 항공 마일리지 연계 결제 API 중계 및 금융 데이터 처리를 수행하는 수탁자에 대한 개인정보 관리·감독 체계 강화 필요
- (주)해랑금융은 (주)하랑항공으로부터 마일리지 연계 결제 서비스 API 중계 및 금융 데이터 처리·정산 업무를 위탁받아 월평균 약 45만 건의 결제 API를 처리하며, 계좌번호·카드번호·결제이력 등 민감한 금융 개인정보를 대량 보관하고 있음
- 개인정보 취급자가 개인정보를 처리함에 있어 분실·도난·유출·위조·변조 또는 훼손되지 않도록 안전성 확보 조치 이행 여부 점검 필요
- 수탁자 자체 점검 결과, 보유기간 초과 결제이력 데이터 미파기, 외주 인력 보안서약서 미징구, NAS 공유폴더 평문 저장 등 복수의 취약 사항이 사전 확인되어 현장 점검을 통한 정밀 확인 요구

3. 점검 개요

- 점검 시기: 26.01.26 (월) ~ 26.02.13 (금)
- 점검 자: (주)리베로
- 점검 대상: (주)해랑금융
- 점검 범위: 개인정보 관리체계 관련 문서 및 개인정보처리시스템 (API Gateway, 결제 DB, SFTP 서버 포함)
- 점검 항목: 3개 범주 14개 영역 53개 항목

※ 수탁자 점검 체크리스트 참조

4. 점검 계획

4.1 사전 제출자료 검토 및 점검

- 수탁자 현황 자료 검토
- 수탁자 현황 자료 기반 현황관리 점검표 작성

4.2 개인정보 관리실태 현장 점검

- 개인정보보호담당자를 통한 각 점검지표 이행 여부 적정성 확인
- 개인정보 관리체계 관련 문서 및 개인정보처리시스템 점검
- 결제 DB, API Gateway, SFTP 서버 등 핵심 금융 처리 시스템 현장 확인

4.3 미흡사항 개선 요청

- 서면 점검, 현장 점검 시 확인된 미흡사항에 대한 개선 요청
- 취약 판정 항목 우선 조치 요청

5. 점검 일정

[표 1] 점검일정표

추진 내용	1월				2월				3월	
	1주	2주	3주	4주	1주	2주	3주	4주	1주	2주
수탁자 현황 검토										
현황관리 점검표 작성										
현장 점검 일정 수립										
현장 실사										
점검결과 보고										

6. 점검 항목

[표 2] 내부 관리 계획 및 조직 점검항목

내부 관리 계획 및 조직	점검항목
개인정보 보호정책	고객 개인정보의 안전한 취급을 위하여 개인정보보호 정책을 수립하여 시행
개인정보 보호조직	개인정보보호 업무를 수행하기 위한 내부조직 구성
개인정보취급자 관리감독	개인정보를 위탁받아 개인정보처리업무를 수행하는 개인정보취급자를 식별하고, 정기적으로 개인정보보호 관련 교육 실시
물리적 보안	개인정보의 유출/훼손을 방지하기 위한 물리적 보호 방안 마련

[표 3] 접근 통제 및 권한 관리 점검항목

접근 통제 및 권한 관리	점검항목
접근 권한	개인정보처리시스템에 대한 접근권한 관리 계정정보 또는 비밀번호 일정 횟수 이상 잘못 입력 시 시스템 접근 제한 등 조치
접근통제	계정정보 또는 비밀번호 일정 횟수 이상 잘못 입력 시 시스템 접근 제한 등 조치

[표 4] 접속기록 보관 및 점검 점검항목

접속기록 보관 및 점검	점검항목
접속기록 관리	개인정보처리시스템의 접속에 대한 로그를 관리

[표 5] 비밀번호 관리 점검항목

비밀번호 관리	점검항목
비밀번호 관리	개인정보처리시스템및 개인PC에 대한 비밀번호 작성 규칙을 수립 및 적용

[표 6] 접속 보안 및 네트워크 점검항목

접속 보안 및 네트워크	점검항목
네트워크 접근권한 관리	개불법적인 접근 및 침해사고 방지 조치

[표 7] 단말기 보안 점검항목

단말기 보안	점검항목
단말기 보안	개인정보를 처리하는 개인 PC/서버등 단말기에 대한 보호 방안을 마련

[표 8] 개인정보 암호화 및 출력 통제 점검항목

개인정보 암호화 및 출력 통제	점검항목
개인정보 암호화	개인정보를 안전하게 보호하기 위하여 암호화를 적용해야 하고 암호화 키는 적절한 절차에 따라 안전하게 관리
개인정보 출력복사보호조치	개인정보의 출력시 보안통제를 적용

[표 9] 개인정보 생명주기 점검항목

개인정보 생명주기	점검항목
개인정보 수집	개인정보 수집·이용시 개인정보 처리에 대한 내용을 안내하고 동의를 받기
개인정보 이용 및 제공	제공받은 개인정보를 제공받은 목적과 다른 목적으로의 이용하지 않기
개인정보 파기	개인정보를 위탁 받은 목적을 달성한 경우 개인정보를 지체없이 파기